Control

8 questions to ask any AI vendor before you sign

Your AI vendor is part of your operational resilience now.

Prepared by	**Christophe Atten**
For	**Finance teams**
Type	**Checklist**

Swipe for all 8 questions



AI tools are ICT services

Since January 2025, EU financial entities must manage ICT third-party risk. DORA also sets out what those contracts must cover.

You need answers you can document.

What good looks like

1 Where exactly is our data processed and stored?

Name the countries and data centres, including backups and support access.

> **Good answer**
> Clear list of locations, EU options, written into the contract.

> **Red flag**
> "Global cloud", no list, or locations that can change without notice.

DORA contract provisions

2 Is our data used to train or improve your models?

Covers prompts, files, outputs and logs.

> **Good answer**
> No, by default and in the contract, with retention periods stated.

> **Red flag**
> Opt-out only, vague wording, or "anonymised data may be used".

Data protection

What good looks like

3 Which subcontractors are involved, including the model provider behind your product?

Most AI tools run on someone else's model.

Good answer

Full list of material subcontractors, notice before changes.

Red flag

Model provider not named, or no notice of changes.

Subcontracting chain

4 What service levels do you commit to, and how are they measured?

Availability, response times, support hours.

Good answer

Quantified SLAs with reporting and remedies.

Red flag

"Best effort" or SLAs only in marketing material.

DORA contract provisions

What good looks like

5 How quickly will you notify us of an incident, and what support do you give?

You have your own reporting deadlines to meet.

Good answer

Defined notification time, named contact, support during the incident.

Red flag

No timeline, or notification only after their own investigation ends.

Incident management

6 Can we, and our supervisor, audit you?

Access, inspection and audit rights, including for regulators.

Good answer

Yes, contractually, with reasonable notice periods.

Red flag

Only third-party certificates, no direct audit rights.

DORA contract provisions

What good looks like

7 How do we get our data back if we leave?

Exit and termination are where weak contracts hurt.

Good answer

Export in a usable format, transition support, deletion confirmed.

Red flag

No export format defined, or exit fees not stated.

Exit strategy

8 What happens when you change or replace the underlying model?

AI-specific: a silent model change can alter every output you rely on.

Good answer

Advance notice, release notes, a way to test before the switch.

Red flag

Models change without notice or documentation.

AI-specific addition

Question 8 isn't spelled out in DORA

But a silent model change can alter every output you rely on.

Ask for notice, release notes and a way to test first.

Do this week

Your first step this week

> Pick your most-used AI tool. Send the vendor these eight questions. The time it takes to answer tells you a lot too.

Free resource

Get the questionnaire

Free. The link is in the post.

No signup.

